

# TWOKEY

Targeted Holds for UPI Fraud on Drunix

Pause only the scams. Make the pause reversible by both banks. Keep legitimate money moving.

# THE VELOCITY OF APP FRAUD DEFEATS POST-TRANSACTION RECOVERY

## THE ATTACK

**Step 1 (Fraudster):**
Victim is socially engineered (fake police, digital arrest).

```
SOCIAL_ENGINEERING_VECTOR
// STATUS: ACTIVE
```

**Step 2 (Victim):**
Victim authenticates UPI transfer to a mule account.

```
UPI_AUTHENTICATION_CONFIRMED
// PAYER_BANK: CYAN //
// PAYEE_BANK: AMBER
```

**Step 3 (Mule):**
Funds are moved onward through layered accounts within minutes.

```
RAPID_FUND_LAYERING //
DESTINATION_NODES: MULTIPLE
// LATENCY: <5 MIN
```

**THE SPEED ASYMMETRY**

## THE RESPONSE

**Step 4 (Recovery - Too Late):**
Victim calls 1930. CFCFRMS system freezes empty downstream accounts.

```
CFCFRMS_FREEZE_REQUEST //
STATUS: PROCESSED //
ACCOUNTS_BALANCE: ₹0.00 //
LATENCY: >4 HOURS
```

**₹22,931 crore** lost to cyber-financial fraud in 2025 (NCRP data). Post-transaction remedies recover very little.

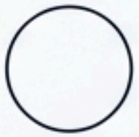
# The Regulatory Dilemma: The RBI's April 2026 Consultation

## Status Quo (100% Instant)

**Mechanism:** No delays.

**Result:** Low friction, but extremely low recovery.

Diagnostic



Fraud Recovery



User Experience

## Blanket Lag (RBI Option 1)

**Mechanism:** Hold all P2P credits above a value floor.

**Result:** High recovery, but unacceptable friction for genuine users.

Diagnostic



Fraud Recovery



User Experience

## TwoKey (Risk-Proportional)

**Mechanism:** Target holds based on tier; require shared control for release.

Diagnostic



Fraud Recovery



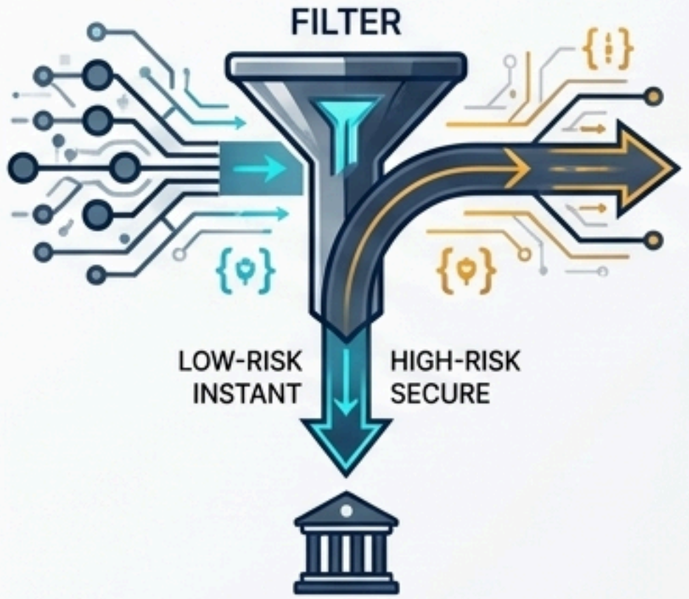
User Experience

**Result:** **≥80%** of blanket lag's recovery, with **≤10%** of blanket lag's delayed genuine transfers.

# The TwoKey Solution Architecture

## 1. Risk Check

Assesses transfer before settlement. Settle low-risk instantly.




## 2. Shared Control (Drunix)

Medium/High-risk credits become a ConditionalCredit. Neither bank can release a mule's money early or claw back a genuine payment alone.

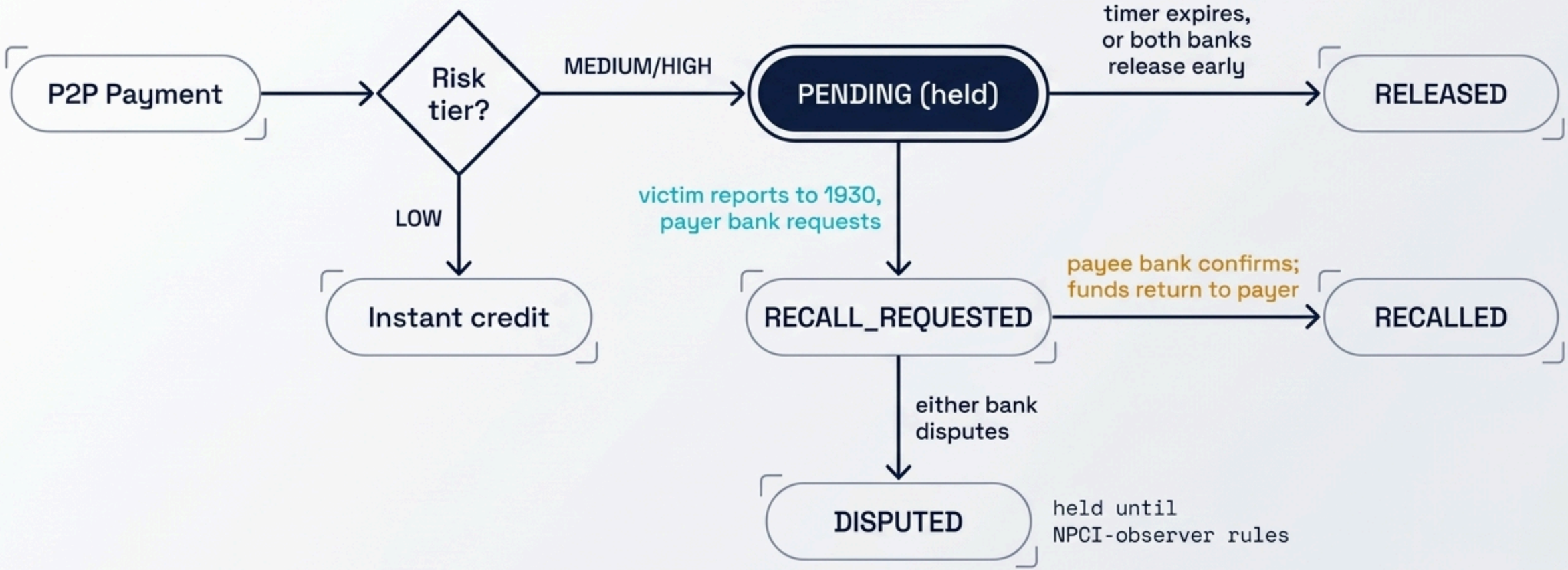


## 3. Pre-Loss Recall

Victims report during the hold. Because money hasn't left the payee account, recall is a simple state change, not a chase through layered accounts.

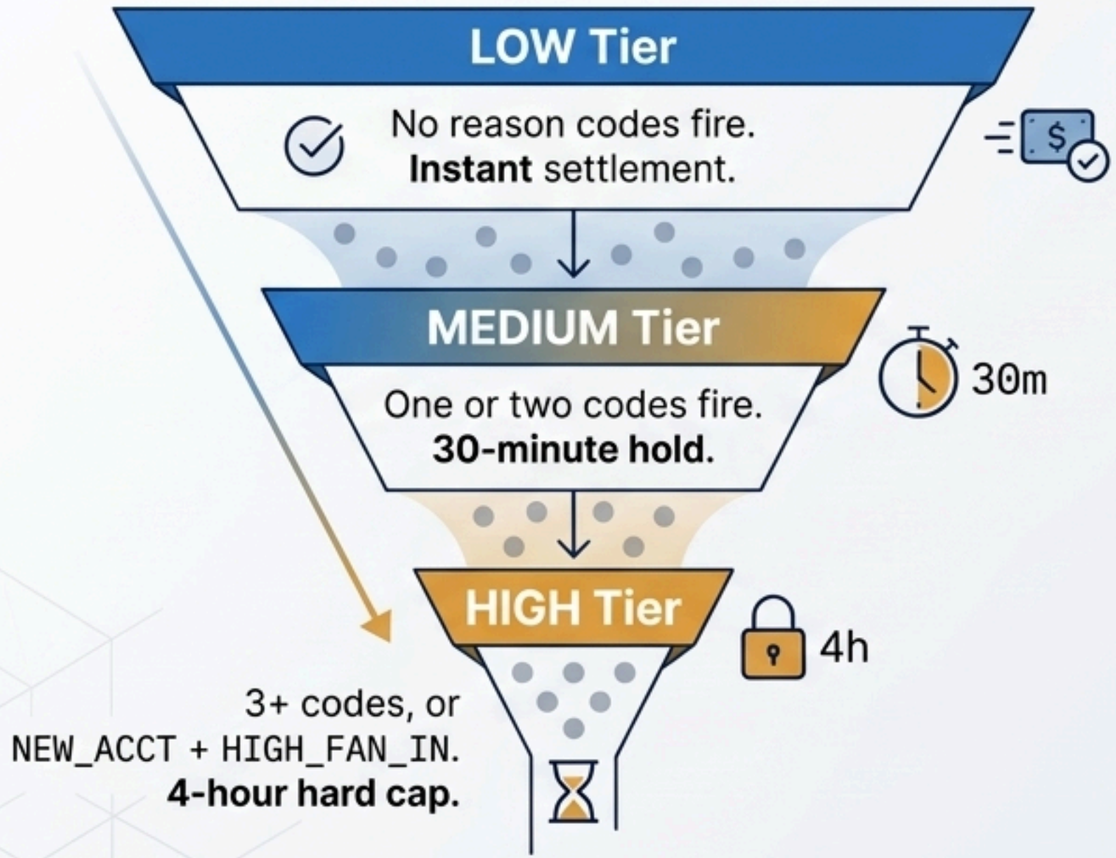


# The Lifecycle of a Conditional Credit



# The Risk-Tier Engine: Rules-First, Explainable Tiering

## SCORING FUNNEL




cryptographic

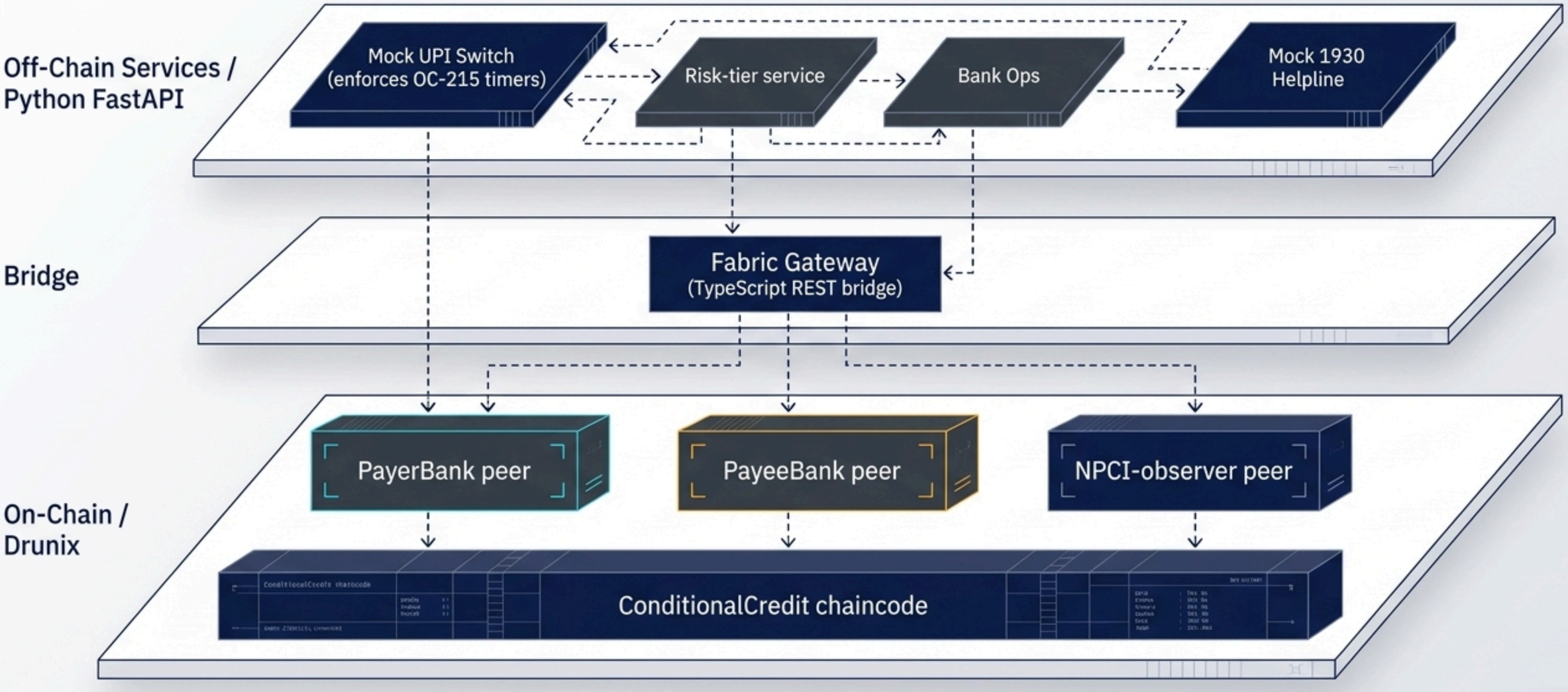
## Key Reason Codes:

| CODE (Monospaced) | EXPLANATION (Sans-serif) |
|---|---|
| NEW_ACCT | Payee account is days/weeks old |
| FIRST_PAYEE | No prior history between parties |
| HIGH_FAN_IN | Distinct payers into payee in last 24h |
| SPLIT_PATTERN | Smurfing around thresholds |

csyptogsaphic

**AI Stretch Goal:** LightGBM classifier with SHAP-based explainability runs alongside rules.

# System Architecture: Python Services Meet Drunix State



# The On-Chain Data Model: Privacy by Design

## The Shared Channel
(What NPCI & Drunix see)

```
struct ConditionalCredit {
    TxnRef,
    AmountPaise,
    HashedPayer,
    HashedPayee,
    Tier,
    ReasonCodes,
    State
}
```

NPCI sees only cryptographic hashes, amounts, and settlement states.

## The Private Data Collection
(What only the 2 Banks see)




PII lives completely off the shared channel. Restricted to bilateral counterparties.

**Regulatory Fit:** Fully compliant with DPDP Act 2023 duties (purpose limitation, minimisation, erasure).

# Why Blockchain? The Necessity of Shared Control

## The Problem with a Central DB



A single bank could unilaterally release a mule's money early or maliciously claw back a genuine payment. Requires placing absolute trust in a central arbiter.

## The Drunix Solution



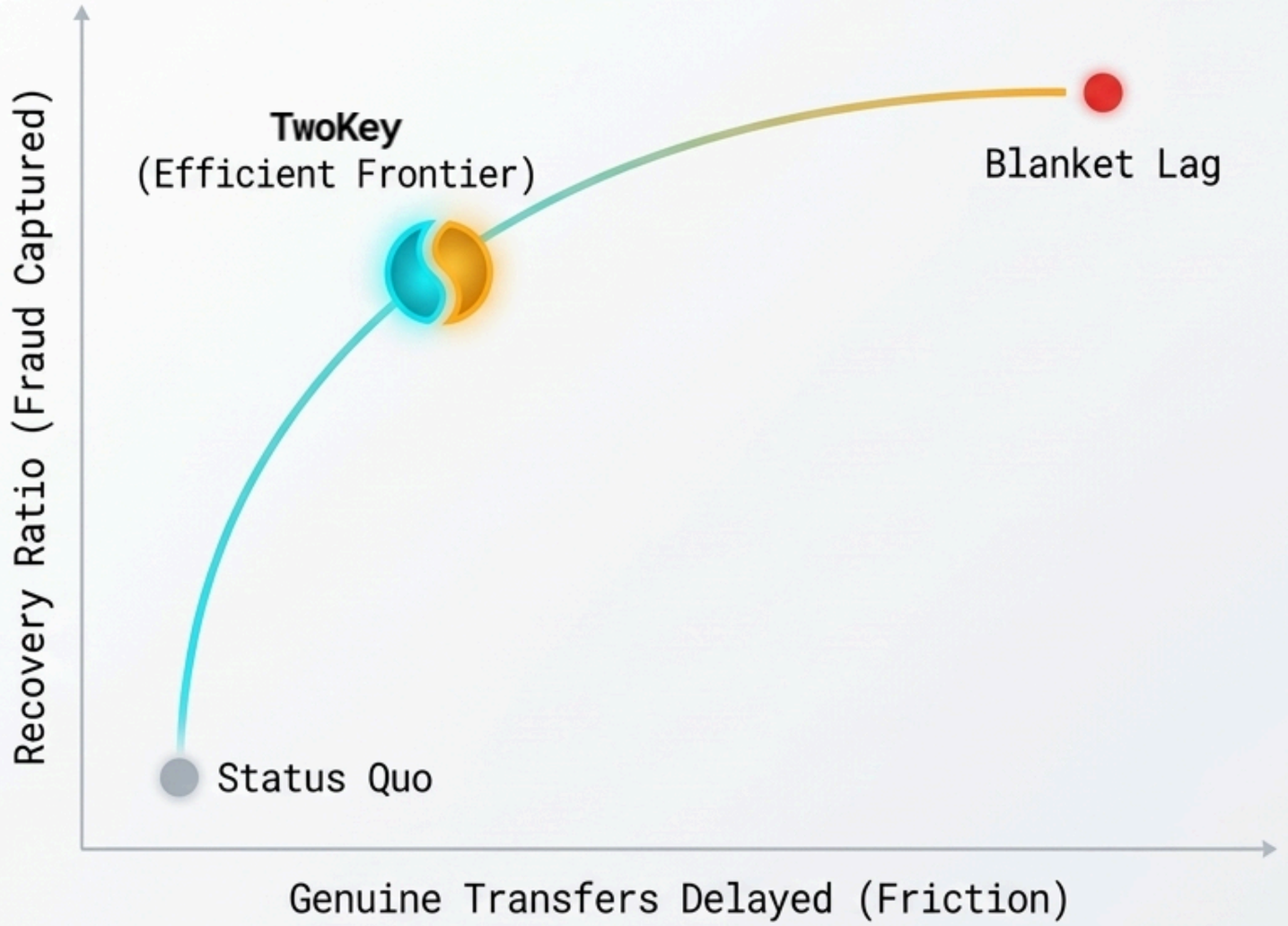
Endorsement policy mandates `AND('PayerBankMSP.peer', 'PayeeBankMSP.peer')` on every state-changing call.

**Result:** A mathematically provable, non-repudiable neutral audit trail. No single entity can force a settlement change. Crucial for fair NPCI dispute resolution.

# Resilience & Adversarial Defense Grid

| Threat | Defense |
| --- | --- |
| Colluding payee bank tries to release early alone. | Endorsement fails on ledger; credit stays `PENDING`. |
| Payer bank recalls without payee bank. | Moves only to `RECALL_REQUESTED`; funds move only on joint confirm. |
| Replayed recall requests. | Rejected; state machine logic is perfectly deterministic. |
| Smurfing many transfers just under the value floor. | `SPLIT_PATTERN` and `HIGH_FAN_IN` velocity features raise the tier to `HIGH`. |

# The Policy Simulator: Quantifying the Trade-Off




## Methodology

1 million synthetic P2P transfers sweeping fraud prevalence (0.05% to 0.5%) and mule cash-out medians (5m to 6h).

## Success Criteria Metrics

- **Target:** Recover ≥ 80% of what a blanket lag recovers.
- **Constraint:** Delay ≤ 10% as many genuine payments as a blanket lag.
- **Chaincode:** 100% deterministic in property tests.

# Global Prior Art vs. The TwoKey Approach

| **UK**<br>(FCA, Nov 2024) | **Singapore**<br>(MAS, Dec 2024) | **India / TwoKey (Proposed)**  |
|---|---|---|
| Allows delaying outbound payments up to 4 business days.<br><br>*Flaw: Payer-side only, highly discretionary, massive friction* | 12-hour cooling period for high-risk activities.<br><br>*Flaw: Triggered by broad account events, not evaluated on per-transfer risk* | Evaluated per-transfer by specific risk. Hold length is strictly capped (`30m`/`4h`).<br><br>**Crucially, the beneficiary's bank shares cryptographic control of the hold. Surgical, not blunt.**  |

# Regulatory Fit & Adoption Path



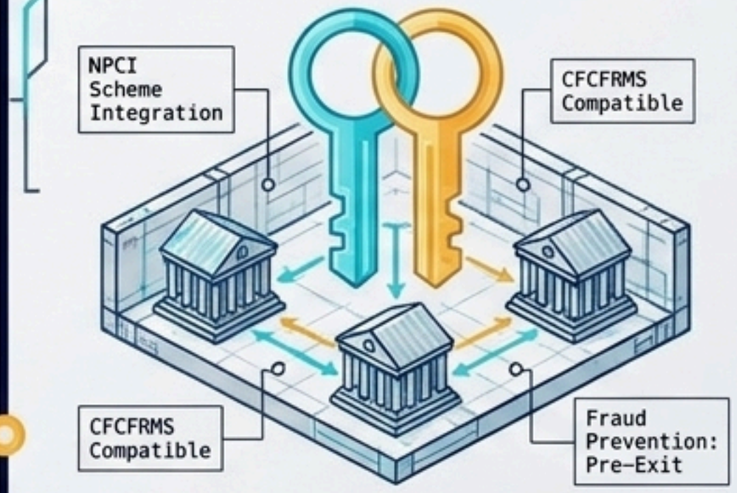
## Horizon 1: On-Us Pilot

Run entirely inside a single bank's ecosystem. Requires no inter-bank consensus or external **protocol changes.**



## Horizon 2: Regulatory Sandbox

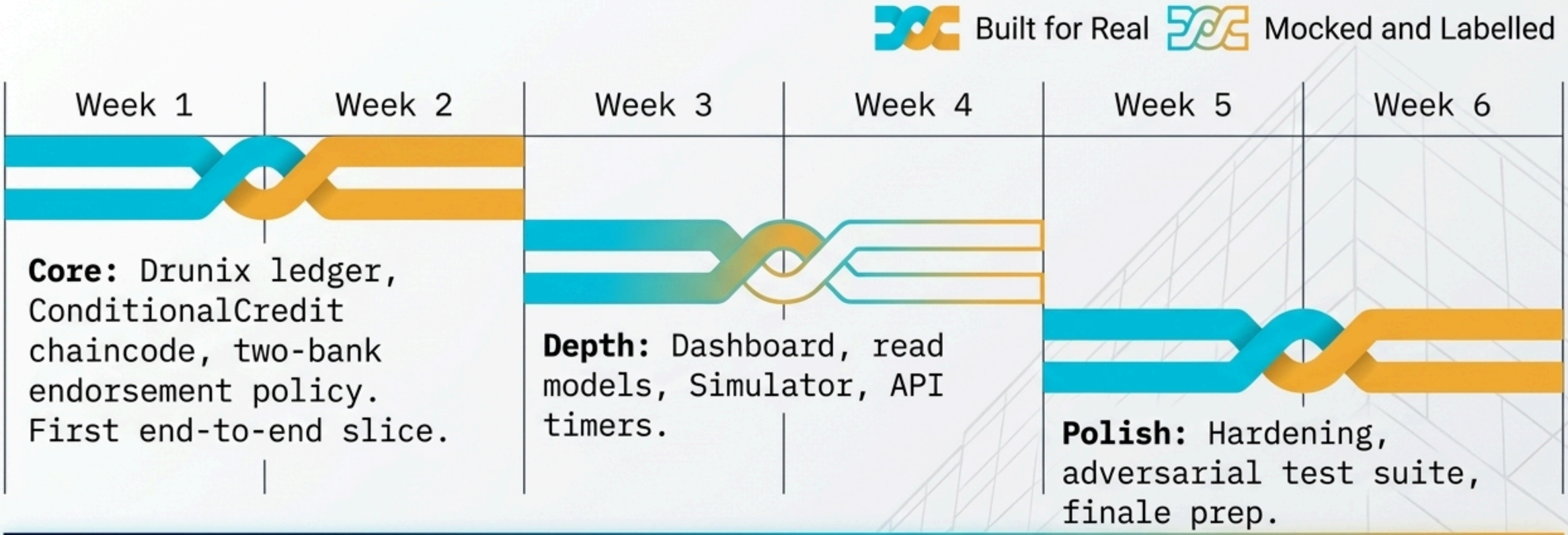
Controlled rollout via NPCI or RBI Regulatory Sandbox involving **two participating** banks interacting on a **live Drunix partition.**




## Horizon 3: Scheme Rule

Nationwide rollout integrated into NPCI scheme rules, working alongside existing **CFCFRMS tools to prevent fraud before funds exit the system.**

# Execution: The 6-Week Build Plan




**Transparency Callout**
The UPI switch, bank core systems, and 1930 helpline are strictly simulated. All Drunix network and chaincode components are built live and run locally.